

## AVANCE DE PROYECTO INTEGRADOR

### Plan de Normas de Seguridad

#### I. ISO 27001

Para implementar el estándar **ISO/IEC 27001:2022** en la empresa automotriz y establecer un Sistema de Gestión de Seguridad de la Información (SGSI) sólido, seguiría el ciclo de mejora continua **PDCA** (Plan-Do-Check-Act) enfocado en los activos críticos del caso:

**1º Fase de Planificación (Plan):** Definiría el alcance del SGSI, incluyendo el Centro de Diseño en Múnich y las plantas de manufactura. Es fundamental realizar un análisis de riesgos para los activos identificados (Mainframes, BD Oracle/DB2 y Red Cisco) y seleccionar los controles aplicables del **Anexo A** de la norma, como el control A.5.15 (Clasificación de la información) para proteger los diseños premium.

**2º Fase de Implementación (Do):** Desplegaría los controles técnicos y administrativos necesarios. Esto incluye eliminar el "Full Access" generalizado mediante el control A.5.18 (Derechos de acceso) y sustituir los antivirus gratuitos por una solución de grado empresarial (EDR).

**3º Fase de Verificación (Check):** Establecería indicadores de cumplimiento y realizaría revisiones periódicas. Por ejemplo, monitorear mediante **Splunk** si se cumplen las políticas de acceso a las bases de datos y si se están realizando los respaldos del 100% de la información.

**4º Fase de Mejora (Act):** Con base en las auditorías internas, realizaría los ajustes necesarios. Si se detecta que el personal sigue descargando software no autorizado (Shadow IT), se reforzaría el programa de concienciación y se ajustarían los bloqueos en el firewall.



## II. Marco de seguridad COBIT

Para alinear la normativa de la empresa con **COBIT**, debemos pasar de solo "gestionar la seguridad" a "**gobernar la información y la tecnología**". COBIT se enfoca en que la TI entregue valor y los riesgos estén alineados con los objetivos del negocio.

Estos son los cambios clave que implementaría en la normativa:

- **Separación de Gobierno y Gestión:** Establecería una norma que distinga claramente las responsabilidades del Consejo Directivo (que evalúa y orienta) de las del equipo de TI (que ejecuta y monitorea).
- **Alineación con Objetivos Estratégicos:** La normativa debe exigir que cada control de seguridad (como el respaldo del 100% de la información) esté vinculado a un objetivo de negocio, como la "Continuidad de la Manufactura".
- **Implementación de Métricas y KPIs:** Cambiaría la norma de "hacer respaldos" por una que exija reportar el **% de éxito de restauración** y el **tiempo de inactividad**, alineándose con el dominio de **MEA (Monitorear, Evaluar y Valorar)** de COBIT.
- **Gestión de Riesgos Transparente:** La normativa obligaría a crear un Registro de Riesgos corporativo donde la alta dirección acepte formalmente los riesgos residuales, especialmente los relacionados con los mainframes obsoletos y la zona sísmica de Múnich.
- **Control de Calidad en el Desarrollo:** Para el software automotriz premium, la norma debe integrar controles de calidad y seguridad desde el diseño (DevSecOps), siguiendo el dominio **BAI (Construir, Adquirir e Implementar)** de COBIT.



### III. Marco NIST

Para que la empresa avance en el marco NIST, la normativa debe modificarse para reflejar el paso de un estado reactivo a uno proactivo:

- **Nivel 1: Parcial (Estado Actual):**

- **Modificación:** La normativa actual es informal y reactiva. Se debe formalizar la existencia de un inventario de activos y una política básica de accesos para dejar de gestionar la seguridad de forma "ad-hoc".

- **Nivel 2: Informado por el Riesgo:**

- **Modificación:** La normativa debe exigir que la alta dirección apruebe formalmente las prácticas de gestión de riesgos. Se debe incluir la obligatoriedad de realizar un análisis de impacto al negocio (BIA) antes de priorizar presupuestos en TI.

- **Nivel 3: Repetible:**

- **Modificación:** Las políticas de seguridad deben estar documentadas, aprobadas y comunicadas a los **35,000 empleados**. La norma debe exigir procesos estandarizados para el parchado de bases de datos (Oracle/DB2) y la renovación de hardware Cisco, asegurando que no dependan del conocimiento de una sola persona.

- **Nivel 4: Adaptativo:**

- **Modificación:** La normativa debe evolucionar para incluir el **monitoreo continuo** y la detección predictiva. Se debe integrar el uso de **Splunk y SOAR** como norma para aprender de eventos pasados y ajustar los controles de forma dinámica antes de que ocurra un nuevo incidente.



## IV. Criterios comunes

Para la empresa automotriz, estos son los criterios que yo incluiría:

- 1º **Evaluación de EAL (Evaluation Assurance Level):** Exigir que cualquier software crítico de control de frenado o motor tenga un nivel de seguridad certificado (ej. EAL4+) para garantizar que ha sido probado contra ataques.
- 2º **Seguridad en el Ciclo de Vida (Flaw Remediation):** Los sistemas deben tener un mecanismo certificado para recibir parches de seguridad de forma segura, evitando que los motores Oracle/DB2 vuelvan a quedar 3 años desactualizados.
- 3º **Protección de Datos en Reposo y Tránsito:** Todo producto de hardware premium desarrollado en Múnich debe cumplir con criterios de cifrado validados (como FIPS 140-2) para evitar que la IP sea robada si un prototipo es interceptado.
- 4º **Autenticación Robusta:** Los sistemas de acceso a la planta y laboratorios deben cumplir con criterios de biometría y MFA que aseguren que el "Full Access" actual sea imposible de explotar por terceros.



## V. Cumplimiento de normas

Para asegurar que las normativas basadas en ISO 27001, COBIT y NIST sean efectivas, implementaremos el siguiente plan de cumplimiento:

### 1º Programa de Concientización y Capacitación (Cultura de Seguridad):

- **Acción:** Realizar talleres trimestrales obligatorios para los 35,000 empleados sobre riesgos de "Shadow IT" (software no autorizado) y phishing.
- **Vínculo:** Cumple con la función de **Proteger** de NIST al reducir el error humano.

### 2º Mecanismos de Control Técnico (Enforcement):

- **Acción:** Configurar el Firewall y el EDR para bloquear automáticamente cualquier instalación no permitida (como *Warzone* o *AnyDesk*), eliminando la posibilidad de incumplir la norma por "descuido".
- **Vínculo:** Alineado con el dominio **BAI** de COBIT (Construir, Adquirir e Implementar).

### 3º Monitoreo Continuo y Auditoría de Cumplimiento:

- **Acción:** Utilizar **Splunk** para generar reportes semanales de cumplimiento. Cualquier desviación (ej. un servidor de base de datos Oracle sin el parche del mes) generará una alerta inmediata al responsable.
- **Vínculo:** Cumple con el dominio **MEA** de COBIT (Monitorear, Evaluar y Valorar).

### 4º Política de Sanciones y Reconocimientos:

- **Acción:** Actualizar el reglamento interior de trabajo para incluir sanciones administrativas a quienes violen deliberadamente las normas de seguridad (ej. compartir diseños premium sin cifrado).
- **Vínculo:** Refuerza la gobernanza exigida por ISO 27001.



## VI. Auditorias

El plan de auditoría se ejecutará bajo un enfoque basado en riesgos, evaluando la eficacia de los controles técnicos y administrativos sobre los activos identificados en el caso.

### 1. Alcance de la Auditoría

Se auditarán los tres pilares que sostienen la operación de las plantas y el centro de diseño:

- **Gestión de Datos:** Motores Oracle, DB2 y SQL Server.
- **Continuidad:** Sistemas y procesos de respaldo y recuperación.
- **Infraestructura de Transporte:** Red Core Cisco y conectividad entre sedes.

### 2. Objetivos y Pruebas Técnicas

| Activo IT                              | Objetivo de la Auditoría                                           | Prueba de Auditoría (Evidencia)                                                                                        |
|----------------------------------------|--------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| <b>Bases de Datos (Oracle/DB2/SQL)</b> | Verificar la integridad y el control de acceso a los diseños e IP. | Revisión de logs de acceso en <b>Splunk</b> , verificación de versiones/parches y pruebas de inyección controladas.    |
| <b>Sistemas de Respaldo</b>            | Validar que el 100% de la información crítica sea recuperable.     | Ejecución de una prueba de restauración completa (Restore Test) y validación de la capacidad de almacenamiento actual. |



| Activo IT      | Objetivo de la Auditoría                                                    | Prueba de Auditoría (Evidencia)                                                                                           |
|----------------|-----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
|                |                                                                             |                                                                                                                           |
| Red Core Cisco | Asegurar la disponibilidad de la comunicación y la segmentación de tráfico. | Análisis de vulnerabilidades en equipos de más de 5 años y revisión de las reglas de ACLs para prevenir el "Full Access". |

### 3. Cronograma de Ejecución

- **Semana 1-2:** Auditoría de Bases de Datos (Prioridad por volumen de I/O y valor de IP).
- **Semana 3:** Auditoría de Resiliencia (RespalDOS y DRP).
- **Semana 4:** Auditoría de Infraestructura de Red y Perímetro.

